

Cyber Attacks Explained

The Botnet Army

This article covers sophisticated botnet attacks, whereby the attacked computer system becomes an attacker itself. Systems administrators and senior technology management staff that are aware of the modus operandi of botnets are best qualified to prevent their entry into a secured network. The article also discusses how FOSS systems ought to be protected from such attacks.



The word 'botnet' is derived from a 'network of robots'. It is essentially a widespread collection of a large number of infected computer systems. Each infected system runs a piece of software program called a 'bot'. As shown in Figure 1, there is a bot-master system, which keeps track of the total number of machines infected and the tasks they should perform. For carefully choreographed attacks that need orchestration between millions of such systems, another layer of bot-managers is created too. These perform the tasks of accepting commands from the master, spreading those commands to the bots, and also reporting the number of infected systems under them. The manager botnets also send software patches to fix bugs or improve functionality, very similar to a security patch management system.

The bot-masters are controlled by the crackers who created this army. However, since the crackers are in hiding, the master system and software running on it are always operating in stealth mode. In a few recent botnet attacks, the bot-master had delegated and rotated the master's role between its bot-managers, thus making it extremely tough to detect. These role changes were further rotated based on the country they were present in. Usually, botnets are designed for a specific OS, and if they have to spread wider, botnets prefer Web code or the Java language to infect all possible OS platforms.

Now, let's look into the internal operations of a typical bot. As shown in Figure 2, there are four main modules of a botnet. The command module sends commands to the child botnets, whereas the control module controls the ownerships, to decide who should listen to whom. The infection module

carries the important responsibility of finding non-patched servers in the network, and infecting those with the most updated copy. The stealth module is essentially a set of software programs, which does crucial jobs such as disabling anti-virus software, achieving root access or kernel access, etc. It also ensures that its own footprint on the infected machine is invisible in terms of running processes and disk space, and also keeps a watch on new anti-virus software being installed. In some cases, the stealth module and control module work together to fetch their most recent patch from the master or manager, and seamlessly upgrade themselves. Some stealth modules are also capable of erasing themselves with a self-destruct mechanism, or shutting down the system to thwart aggressive detection techniques.

The way botnets interact with the master or manager is very interesting too. All bots are given a unique identification number, which is usually a product of the infected system's configuration and location, but not necessarily the IP address of the system. The master always has the most updated count of the identification numbers used, and is capable of limiting or expanding the spread. Bots use a specific range of TCP ports; however, the exact port being used is picked randomly. It is always the duty of the botnet to report to the master or manager the TCP port number it plans to use. This reporting occurs on every reboot of the infected system. In most cases, the inter-bot communications are Base-64 or MD5 encrypted, while in some cases a self-signed digital certificate is used too.

The main purpose behind infecting a botnet into a system is to create an army of infected systems, also called zombies. The